

Informe COBIT.

El núcleo de COBIT 2019 para ciberseguridad a nivel país pasa por usar sus objetivos de gobierno y gestión (sobre todo EDM03, APO12, APO13, DSS04, DSS05, MEA01-03) como esqueleto de indicadores, y luego “nacionalizarlos” con métricas que se puedan alimentar desde los observatorios e índices de ciberseguridad (NCSI, GCI, etc.) que ya miden a España y al resto del mundo. La gracia está en que COBIT aporta la lógica de gobierno (qué medir, dónde y para qué) y los índices nacionales aportan el termómetro comparativo global.¹²³⁴⁵⁶

1. COBIT 2019 y su capa de métricas

- COBIT 2019 amplía COBIT 5 hasta 40 objetivos de gobierno y gestión agrupados en 5 dominios: EDM, APO, BAI, DSS y MEA.⁷¹
- ISACA publica para cada objetivo un conjunto de prácticas, actividades y métricas sugeridas de entrada (KGI/KPI), que luego se adaptan al contexto.⁶⁷
- El modelo COBIT Performance Management (CPM) usa niveles de capacidad y madurez alineados con CMMI V2.0 para cuantificar desempeño y evolución.⁸⁹¹⁰
- El foco “Information Security” de COBIT añade métricas específicas de seguridad a los objetivos más críticos (APO13, DSS05, BAI06, etc.).¹¹⁶

Ejemplo sencillo: para APO13 (Managed Security) COBIT propone medir el grado de implantación del SGSI, cumplimiento de políticas y evolución del riesgo residual de información.⁷⁸⁹

2. Objetivos COBIT más relevantes para ciberseguridad nacional

Para articular indicadores de nivel país, los objetivos COBIT de seguridad se convierten en “categorías” de medida:

¹ <https://www.isaca.org/resources/cobit>

² <https://dialnet.unirioja.es/servlet/articulo?codigo=8750168>

³ <https://www.isaca.org/resources/news-and-trends/industry-news/2021/using-cobit-2019-to-proactively-mitigate-the-impact-of-covid-19>

⁴ <https://www.aasmr.org/jsms/Vol14/No.3/Vol.14.No.3.08.pdf>

⁵ <https://www.isaca.org/resources/news-and-trends/industry-news/2021/using-cobit-2019-to-proactively-mitigate-the-impact-of-covid-19>

⁶ <https://ncsi.ega.ee/country/es/>

⁷ <https://www.isaca.org/resources/COBIT>

⁸ <https://icobits.ubhinus.ac.id/index.php/ICoBITS/article/download/8/4>

⁹ <https://www.linkedin.com/learning/cybersecurity-foundations-22006082/managing-security-with-cobit>

- EDM03 – Ensured risk optimization: monitorear objetivos y métricas de gobierno del riesgo, analizar desviaciones y activar acciones correctoras.⁴⁷
- APO12 – Managed Risk: consolidar el perfil de riesgo de I\&T, criterios de apetito/tolerancia y el cumplimiento de los procesos de gestión de riesgos.¹⁴¹²³
- APO13 – Managed Security: diseñar, operar y vigilar un SGSI empresarial, con plan de seguridad, objetivos y revisión continua.¹²¹³¹⁴
- BAI06 – Managed IT Changes: asegurar que los cambios de TI (incluidos de seguridad) se gestionen con evaluación de riesgos y pruebas, minimizando incidentes.¹¹³
- DSS04 – Managed Continuity: gestión de continuidad y recuperación ante incidentes, incluyendo escenarios de ciberataque masivo.³⁴
- DSS05 – Managed Security Services: servicios de seguridad (monitorización, controles de acceso, protección de red/endpoint, gestión de vulnerabilidades, etc.).¹⁵¹²¹¹
- MEA01/MEA02/MEA03 – Monitor \& Evaluate: recopilación, validación y evaluación de métricas de desempeño, conformidad y sistema de control interno.¹⁵⁷

Estos objetivos son los ladrillos estructurales sobre los que se construye el tablero de indicadores nacionales.

3. Tendencias recientes (desde 2025) en indicadores COBIT para ciberseguridad

3.1. De “checklist” a gestión de desempeño (CPM)

- La línea de trabajo de ISACA refuerza el uso del modelo COBIT Performance Management para medir el avance respecto a objetivos y KPIs, no solo “cumplir el marco”.¹⁶¹⁰⁸
- Se promueve vincular cada objetivo (por ejemplo APO13 o DSS05) con KPIs ponderados según su importancia en el Balanced Scorecard de TI: eficacia, eficiencia, satisfacción del negocio y futuro.¹⁷¹⁶

Traducción práctica a nivel país: dejar de contar solo “cuántas normas tenemos” y empezar a medir cuánto reduce el riesgo o mejora la resiliencia cada iniciativa.

3.2. Profundización del área de Seguridad de la Información

- El “Focus Area: Information Security” de COBIT desarrolla prácticas y métricas específicas de seguridad a partir del modelo base, destacando APO13 y DSS05 como ejes.⁶¹¹
- Estudios recientes usan COBIT 2019 junto con ISO 27001 para evaluar 10-12 dominios de seguridad (EDM03, APO11-13, BAI06, BAI10, DSS02-06) con indicadores de madurez promedio y brechas frente al nivel objetivo.¹²³

Esto se presta muy bien a cuadros nacionales de madurez sectorial (sanidad, energía, financiero...) usando la misma lógica de métricas.

3.3. Convergencia con NIST CSF y marcos nacionales

- ISACA publicó una guía específica para implementar el NIST Cybersecurity Framework usando COBIT 2019, alineando funciones Identify-Protect-Detect-Respond-Recover con objetivos como APO12, APO13, DSS04-05, MEA01.1814
- Trabajos académicos y revisiones bibliográficas proponen COBIT 2019 como esqueleto de gobierno complementado con NIST CSF para la capa táctica de controles.²¹⁴

En clave española, esto facilita la alineación con el Esquema Nacional de Seguridad y con las exigencias de la Directiva NIS2.

3.4. Uso intensivo de modelos de madurez

- Se están proponiendo metodologías nuevas de evaluación de madurez COBIT 2019 para cuantificar el desempeño de la gobernanza de TI y seguridad.⁹¹⁰
- Casos de estudio recientes muestran análisis de brechas donde subdominios como APO13 o DSS05 se valoran en niveles CMMI (ej. nivel 2 frente a objetivo 4) y se vinculan a indicadores cuantitativos (incidentes, tiempos de respuesta, etc.).¹⁹¹²

Aplicado a un país, esto permite informes de “madurez media nacional por dominio COBIT”, comparables entre países.

4. Propuesta de indicadores COBIT de ciberseguridad a nivel nacional (España)

A partir de los objetivos y tendencias anteriores, se pueden proponer indicadores “COBIT-compatibles” para una encuesta o informe nacional. Aquí va una selección, con tono apto para encuesta inquisitiva pero civilizada.

4.1. EDM03 – Gobierno y optimización del riesgo

- Porcentaje de organismos con una función formal de gobierno de ciberseguridad que reporte a nivel ejecutivo (ministro, secretario de Estado, etc.).⁵⁴
- Existencia y actualización de una estrategia nacional de ciberseguridad con objetivos cuantificados y revisados periódicamente.⁵
- Nivel de integración de la ciberseguridad en los mecanismos de gobierno corporativo de empresas críticas (consejos, comités de riesgo).²

Preguntas tipo encuesta:

- “¿Con qué frecuencia revisa el máximo órgano de gobierno de su organización (consejo, comité ejecutivo) los indicadores de riesgo de ciberseguridad alineados con COBIT (EDM03/EDM05)?”
- “¿Dispone su organización de apetito y tolerancia al riesgo de ciberseguridad formalmente aprobados y aplicados en decisiones de inversión?”

4.2. APO12 – Gestión del riesgo de TI

Indicadores:

- Porcentaje de organizaciones que han definido, documentado y aplicado un proceso de gestión de riesgos de TI alineado con COBIT APO12 y marcos nacionales.²⁰¹⁴³
- Cobertura de activos críticos identificados y evaluados (porcentaje de sistemas críticos con análisis de riesgos documentado en los últimos 12 meses).
- Número de decisiones de negocio relevantes (fusiones, lanzamientos digitales, externalizaciones) sometidas a evaluación de riesgo de ciberseguridad.

Preguntas sugeridas:

- “Cuando toma decisiones sobre nuevos proyectos digitales, ¿en qué medida se consideran explícitamente los riesgos de ciberseguridad (según un proceso formal APO12)?”
- “¿Qué porcentaje de sus activos críticos dispone de un análisis de riesgos actualizado en el último año?”

4.3. APO13 – Seguridad gestionada (SGSI nacionalizado)

Indicadores típicos orientados a España:

- Porcentaje de organizaciones críticas con SGSI certificado o alineado con ISO 27001 y gestionado bajo un esquema APO13 (políticas, roles, ciclo PDCA).²¹¹³³
- Porcentaje de entidades del sector público sujetas al ENS con cumplimiento efectivo (no solo declarativo) medido con indicadores COBIT (grado de implementación de prácticas APO13).
- Porcentaje de presupuesto TIC dedicado a ciberseguridad y gobierno de la información (como proxy de prioridad estratégica).²

Preguntas con un toque irónico:

- “En la práctica, ¿el SGSI de su organización es un organismo vivo que se revisa y alimenta, o más bien un fósil magnífico que se exhibe solo en auditoría?”
- “¿Quién manda realmente en seguridad: el plan APO13 o el excel improvisado del último incidente?”

4.4. BAI06 – Gestión de cambios de TI

Indicadores:

- Porcentaje de cambios relevantes en sistemas críticos que incluyen evaluación de impacto en ciberseguridad antes de su aprobación.¹¹³
- Porcentaje de incidentes de seguridad atribuibles a cambios mal evaluados o mal probados.
- Nivel de automatización de pruebas de seguridad en el pipeline de cambios (DevSecOps) en servicios clave.

Preguntas:

- “¿En qué medida se evalúa sistemáticamente el impacto en ciberseguridad de los cambios de TI (según prácticas BAI06) antes de su puesta en producción?”
- “¿Cuántos de sus incidentes de seguridad en el último año provenían de cambios no controlados o insuficientemente probados?”

4.5. DSS05 – Servicios de seguridad

Aquí está el corazón operacional de la ciberseguridad nacional:

- Porcentaje de organizaciones críticas con capacidades de monitorización continua (SOC propio o compartido) alineadas con DSS05 (detección, correlación, respuesta).151211
- Tiempo medio de detección (MTTD) y respuesta (MTTR) de incidentes significativos a nivel sectorial y nacional.
- Porcentaje de vulnerabilidades críticas resueltas dentro de los plazos establecidos en la política nacional o sectorial.
- Cobertura de endpoints, redes y aplicaciones con controles de seguridad activos (EDR, WAF, segmentación, etc.).32

Preguntas tipo encuesta:

- “Cuando ocurre un incidente, ¿miden sistemáticamente tiempos de detección y respuesta? ¿Son héroes organizados o bomberos voluntarios en chancas?”
- “¿Qué porcentaje de sus sistemas está bajo monitorización centralizada, y qué porcentaje ‘volando bajo el radar’?”

4.6. DSS04 – Continuidad

Indicadores:

- Porcentaje de organizaciones críticas con Plan de Continuidad de Negocio y Plan de Recuperación ante Desastres probados en los últimos 12 meses.4
- RTO y RPO medios para servicios esenciales, y porcentaje de servicios que cumplen objetivos en pruebas reales.
- Número de ejercicios de simulación de ciberincidente a gran escala (ejercicios nacionales, sectoriales) por año.2

Preguntas:

- “¿Realiza su organización simulacros de ciber crisis con participación de la alta dirección, o sigue siendo un deporte exclusivamente técnico?”
- “¿Conoce y prueba periódicamente los RTO/RPO de sus servicios críticos?”

4.7. MEA01-03 – Monitorización y evaluación

Indicadores:

- Porcentaje de organizaciones que recogen, validan y evalúan objetivos y métricas de ciberseguridad de forma periódica (mínimo trimestral).715
- Existencia de un cuadro de mando integral de ciberseguridad alineado con COBIT (perspectivas negocio, clientes, procesos, futuro).1716
- Número de auditorías internas/externas de seguridad realizadas y porcentaje de acciones correctivas cerradas en plazo.

Preguntas:

- “¿Dispone su organización de un cuadro de mando regular de ciberseguridad con objetivos y métricas claramente definidos, o la ‘métrica’ principal sigue siendo el volumen de correos de alerta?”
- “¿Con qué frecuencia se revisa la eficacia del sistema de control interno de ciberseguridad (MEA02)?”

5. España en el contexto internacional: índices y COBIT

Los grandes índices nacionales permiten “colgar” los indicadores COBIT en un contexto comparativo.

5.1. NCSI, GCI y otros índices

- El National Cyber Security Index (NCSI) sitúa a España con un alto nivel de cumplimiento en indicadores estratégicos (liderazgo, estrategia, protección de infraestructuras, gestión de incidentes, etc.).⁵
- Cada indicador del NCSI se define como “qué se mide” y “qué evidencias se aceptan”: leyes, estrategias, centros de respuesta, programas de formación, etc.⁵
- Muchos de esos indicadores pueden mapearse directamente a dominios COBIT, especialmente EDM, APO y DSS.¹⁴²

Ejemplo de mapeo:

Dimensión índice	Indicador índice (ej.)	Objetivos COBIT relacionados
Liderazgo estratégico	Responsabilidad formal de ciberseguridad a alto nivel	EDM01/EDM03, APO1354
Estrategia nacional	Estrategia de ciberseguridad vigente	APO02, APO12, APO13514
Gestión de incidentes	Existencia de CSIRT nacional y sectoriales	DSS02, DSS05, MEA0152
Protección de infraestructuras críticas	Regulación y medidas específicas	APO12, APO13, DSS04-0523

5.2. Aterrizaje para España

- España cuenta con un Consejo Nacional de Ciberseguridad, estrategia nacional y marcos normativos como el ENS y la transposición de NIS/NIS2; estos elementos cubren buena parte de los requisitos de liderazgo y estrategia que NCSI y otros índices valoran.⁵
- El reto está menos en la existencia de marcos y más en la medición homogénea de su implementación en sectores y territorios, donde COBIT ofrece una taxonomía y lógica de indicadores reutilizable.¹⁴²

Un “Informe COBIT España” razonable podría presentar, por dominio COBIT, la madurez media nacional (niveles COBIT/CPM) y compararla con promedios UE/G20.

6. Esbozo de cuestionario/encuesta COBIT-ciberseguridad (tono propositivo)

Algunas preguntas tipo, agrupadas por dominios COBIT y pensadas para organismos españoles (públicos y privados) con vocación de comparativa internacional:

- **Gobierno (EDM)**
 - “¿Con qué frecuencia el máximo órgano de gobierno revisa un cuadro de mando de ciberseguridad alineado con los objetivos COBIT relevantes (EDM03, APO12, APO13, DSS05)?”
 - “¿Existen criterios formales de apetito al riesgo de ciberseguridad que condicionen la aprobación de proyectos significativos?”
- **Gestión del riesgo y seguridad (APO12, APO13)**
 - “Indique el porcentaje aproximado de sistemas críticos con análisis de riesgos realizado o actualizado en el último año.”
 - “Valore del 1 al 5 el grado en que el SGSI orienta decisiones reales (no solo auditorías) en su organización.”
- **Entrega y continuidad (DSS04, DSS05)**
 - “¿Cuál es el tiempo medio de detección de incidentes significativos en su organización?”
 - “¿Ha realizado simulacros de ciber crisis con participación de niveles directivos en los últimos 12 meses?”
- **Monitorización y mejora (MEA)**
 - “¿Dispone de KPIs formales de seguridad vinculados a objetivos de negocio, con metas cuantificadas y seguimiento periódico?”
 - “¿Cuántas acciones de mejora derivadas de auditorías o incidentes se han cerrado dentro del plazo comprometido?”
- “¿Con qué frecuencia el máximo órgano de gobierno revisa un cuadro de mando de ciberseguridad alineado con los objetivos COBIT relevantes (EDM03, APO12, APO13, DSS05)?”
- “¿Existen criterios formales de apetito al riesgo de ciberseguridad que condicionen la aprobación de proyectos significativos?”
- “Indique el porcentaje aproximado de sistemas críticos con análisis de riesgos realizado o actualizado en el último año.”
- “Valore del 1 al 5 el grado en que el SGSI orienta decisiones reales (no solo auditorías) en su organización.”
- “¿Cuál es el tiempo medio de detección de incidentes significativos en su organización?”
- “¿Ha realizado simulacros de ciber crisis con participación de niveles directivos en los últimos 12 meses?”

- “¿Dispone de KPIs formales de seguridad vinculados a objetivos de negocio, con metas cuantificadas y seguimiento periódico?”
- “¿Cuántas acciones de mejora derivadas de auditorías o incidentes se han cerrado dentro del plazo comprometido?”

Este tipo de preguntas, bien agregadas, permitirían pintar un mapa COBIT-ciberseguridad de España y compararlo con países que adopten instrumentos similares.

¿Quieres que bajemos un nivel más y diseñemos un cuadro de mando completo (con fórmulas de KPI y escalas de madurez) específico para, por ejemplo, Administraciones Públicas españolas o para un sector concreto como sanidad o energía?

222324252627282930313233343536373839404142